

DOCUMENTO TÉCNICO DE SEGURANÇA

# Levantamento de Segurança do Backend

Plataforma de Achados e Perdidos para Grandes Eventos — API (Spring Boot)

|               |                                                            |
|---------------|------------------------------------------------------------|
| Versão        | 1.1                                                        |
| Data          | 24 de julho de 2026                                        |
| Escopo        | Backend / API REST                                         |
| Referência    | OWASP Top 10 (2021); Relatório DAST XPTO v1.0 (24/07/2026) |
| Classificação | <b>Confidencial</b>                                        |

Revisão 1.1 — incorpora o cruzamento com o Relatório Técnico de Avaliação de Segurança (DAST) da XPTO e as correções de hardening dele decorrentes.

# 1. Sumário Executivo

Este documento consolida a análise de segurança da camada de backend da plataforma, compara a implementação real com o que a documentação funcional descreve, detalha o tratamento do OWASP Top 10 (2021) presente no código e responde aos questionamentos técnicos levantados pelo cliente sobre arquitetura, persistência/armazenamento e pipeline.

A avaliação geral é positiva: a base de segurança está acima da média para um MVP, com JWT robusto, proteção a força-bruta, autorização granular por permissão, IDs de recurso assinados (anti-IDOR) e senhas com BCrypt. Durante a revisão foi identificada e já corrigida uma vulnerabilidade de leitura arbitrária de arquivo no módulo de anexos; os demais pontos são recomendações de hardening e de alinhamento entre documentação e implementação.

**Novidade da revisão 1.1 — cruzamento com o relatório DAST externo (XPTO).** Em 20/07/2026 a XPTO executou varredura dinâmica não autenticada (OWASP ZAP + núclei) sobre os ativos do projeto e emitiu relatório em 24/07/2026. O único achado Alto (A-01, exposição de PII) foi triado como **falso positivo** (ruído de telemetria do Firefox, fora dos domínios do projeto). Dos cinco achados Médios confirmados, todos recaem sobre *hardening* de cabeçalhos/exposição e **todos os que tocam o backend já estavam tratados ou foram fechados nesta revisão** — ver a Seção 6 (referência cruzada). Ressalva importante do próprio relatório: a varredura não exercitou os endpoints autenticados da API (o scanner recebeu o *fallback* HTML da SPA em vez das respostas reais), de modo que autorização em nível de objeto/função (BOLA/BFLA) permanece a ser validada por teste autenticado — item já previsto no roadmap (Seção 5).

**Destaques já implementados:** autenticação JWT com fail-fast de segredo fraco · rotação e revogação de refresh token · rate limit de login por IP e por conta · autorização por permissão ( `módulo.acao` ) · IDs assinados por HMAC · SCA de dependências (Trivy) no pipeline · BCrypt · CORS configurável · auditoria de acesso · cabeçalhos de segurança HTTP (HSTS, CSP, nosniff, frame-options DENY, Referrer-Policy).

# 2. Correções Aplicadas

## 2.1 Revisão 1.0 — módulo de anexos

A revisão 1.0 identificou e corrigiu, no módulo de arquivos ( `ArquivoService` / `ArquivoController` ), os seguintes pontos:

| Item                                           | Sev.           | Descrição e correção                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|------------------------------------------------|----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Path Traversal / leitura de arquivo arbitrário | <b>Crítico</b> | O caminho físico do arquivo era resolvido sem confinamento na pasta base, permitindo que um metadado com <code>nmPath</code> absoluto (ex.: <code>/etc/passwd</code> ) ou com <code>../</code> lesse arquivos fora do diretório de anexos. <b>Correção:</b> método central <code>resolverDentroDaBase()</code> que normaliza e exige que o caminho permaneça dentro de <code>app.arquivos.dir</code> , recusando caminhos absolutos e traversal. Aplicado no upload e no download. |
| XSS armazenado via download                    | <b>Alto</b>    | O download servia o conteúdo com <code>Content-Disposition: inline</code> e o content-type gravado, permitindo renderizar HTML/SVG malicioso no domínio da API. <b>Correção:</b> <code>attachment</code> + header <code>X-Content-Type-Options: nosniff</code> e sanitização do nome do arquivo no cabeçalho.                                                                                                                                                                      |

| Item                         | Sev.         | Descrição e correção                                                                                        |
|------------------------------|--------------|-------------------------------------------------------------------------------------------------------------|
| Upload sem validação de tipo | <b>Médio</b> | Qualquer tipo de arquivo era aceito. <b>Correção:</b> allowlist de MIME (JPEG, PNG, WEBP, GIF, HEIC e PDF). |

## 2.2 Revisão 1.1 — hardening em resposta ao relatório DAST XPTO

Esta revisão fechou, no backend, os dois pontos do relatório XPTO que ainda não eram explícitos no código (M-01 e a verbosidade de erro de M-04). Os demais achados que tocam a API já estavam tratados desde a revisão 1.0 (Seção 6).

| Item                            | Ref.      | Descrição e correção                                                                                                                                                                                                                                                                                                                              |
|---------------------------------|-----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Content Security Policy ausente | XPTO M-01 | A API não emitia Content-Security-Policy. <b>Correção:</b> política adicionada em SecurityConfig — default-src 'self', frame-ancestors 'none', object-src 'none', base-uri 'self', form-action 'self'. As diretivas 'unsafe-inline' em script/style existem apenas para a UI do Swagger (dev), desligada em produção por SPRINGDOC_ENABLED=false. |
| Verbosidade do handler de erro  | XPTO M-04 | Fixado explicitamente em application.properties: server.error.include-stacktrace=never, include-message=never, include-binding-errors=never, include-exception=false. Nenhum detalhe interno (stacktrace, tipo/mensagem de exceção) vaza ao cliente; o diagnóstico completo fica apenas no log via GlobalExceptionHandler.                        |

Correções validadas com `mvn compile` (BUILD SUCCESS). Arquivos alterados na revisão 1.1: `config/SecurityConfig.java`, `resources/application.properties`.

## 3. OWASP Top 10 (2021) — Como é Tratado no Backend

A tabela abaixo mapeia cada categoria do OWASP Top 10 ao controle correspondente já presente no código, com a evidência (arquivo). Legenda de status: **Coberto** **Parcial / recomendação** **Corrigido/reforçado nesta revisão**.

| Categoria                    | Status                       | Controle implementado & evidência                                                                                                                                                                                                                                                                                                                                         |
|------------------------------|------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| A01 — Broken Access Control  | <b>Coberto</b><br><b>Fix</b> | Autorização por permissão granular <code>@PreAuthorize("@authz.pode('modulo.acao'))</code> com <code>@EnableMethodSecurity</code> ; regras por rota em SecurityConfig; IDs de recurso assinados por HMAC (impedem IDOR/enumeração); path traversal de arquivos confinado. SecurityConfig.java, AuthorizationService.java, SignedResourceIdCodec.java, ArquivoService.java |
| A02 — Cryptographic Failures | <b>Coberto</b>               | Senhas com BCrypt; JWT assinado HS256 com segredo forte obrigatório (fail-fast se ausente/curto/exemplo); IDs assinados com HMAC-SHA256; segredos sem valor default (não sobem sem variável de ambiente). JwtUtil.java, SignedResourceIdCodec.java, application.properties                                                                                                |
| A03 — Injection              | <b>Coberto</b><br><b>Fix</b> | Acesso a dados via Spring Data JPA parametrizado (sem concatenação de SQL); Bean Validation ( <code>@Valid</code> ) nas DTOs; <code>fail-on-unknown-properties</code> rejeita campos extras; XSS de download mitigado (attachment + nosniff). repository/*, GlobalExceptionHandler.java, ArquivoController.java                                                           |

| Categoria                                      | Status                           | Controle implementado & evidência                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|------------------------------------------------|----------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| A04 — Insecure Design                          | <b>Coberto</b>                   | Tokens tipados (access/refresh) com rotação e revogação de refresh via <code>jti</code> persistido; rate limit aplicado antes da verificação de credenciais; contato de confiança no fluxo de claim. <code>AuthService.java</code> , <code>LoginRateLimiter.java</code>                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| A05 — Security Misconfiguration                | <b>Coberto</b><br><b>Fix</b>     | Recusa de segredos de exemplo; <code>ddl-auto=validate</code> ; <code>open-in-view=false</code> ; CSRF desabilitado corretamente (API stateless com Bearer); CORS configurável sem curinga com credenciais; Swagger desligável em produção ( <code>SPRINGDOC_ENABLED</code> ); allowlist de MIME; <b>cabeçalhos de segurança completos — HSTS, Content-Security-Policy, X-Content-Type-Options nosniff, X-Frame-Options DENY + frame-ancestors 'none', Referrer-Policy; handler de erro sem verbosidade</b> ( <code>server.error.include-*=never</code> ). Recomenda-se ainda <code>useSSL=true</code> no MySQL. <code>SecurityConfig.java</code> , <code>application.properties</code> , <code>CorsConfig.java</code> |
| A06 — Vulnerable & Outdated Components         | <b>Coberto</b><br><b>Parcial</b> | Stack recente (Spring Boot 4.0.2, JDK 25); pipeline de segurança com SCA (Trivy), SAST (Semgrep) e secret scanning (gitleaks). Jobs visíveis a cada execução ( <code>allow_failure</code> na fase de triagem; viram gate bloqueante ao remover o flag). <code>pom.xml</code> , <code>.gitlab-ci.yml</code>                                                                                                                                                                                                                                                                                                                                                                                                             |
| A07 — Identification & Authentication Failures | <b>Coberto</b>                   | Proteção a força-bruta (Bucket4j) por IP e por conta; mensagem genérica anti-enumeração de usuário; JWT stateless; BCrypt; refresh rotativo e revogável. <code>LoginRateLimiter.java</code> , <code>AuthController.java</code> , <code>AuthService.java</code>                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| A08 — Software & Data Integrity Failures       | <b>Coberto</b><br><b>Fix</b>     | Integridade/anti-adulteração dos IDs via HMAC com comparação em tempo constante ( <code>MessageDigest.isEqual</code> ); refresh tokens persistidos e revogáveis; validação de MIME no upload; SCA de dependências (cadeia de suprimentos). <code>SignedResourceIdCodec.java</code> , <code>ArquivoService.java</code> , <code>.gitlab-ci.yml</code>                                                                                                                                                                                                                                                                                                                                                                    |
| A09 — Security Logging & Monitoring Failures   | <b>Coberto</b><br><b>Parcial</b> | Registro de acesso no login (IP, dispositivo, User-Agent); módulo de auditoria de ações. Recomenda-se auditar também o acesso a dados sensíveis (exigência LGPD/documentação). <code>AuthService.java</code> , <code>LoginLogService</code> , <code>entity/Auditoria.java</code>                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| A10 — Server-Side Request Forgery (SSRF)       | <b>Baixa exposição</b>           | Não há requisições de saída construídas a partir de entrada do usuário — superfície mínima. Ao integrar e-mail transacional/S3, os endpoints devem ser fixados por configuração (nunca derivados de entrada do cliente).                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |

## 4. Respostas aos Questionamentos

### 4.1 "A documentação fala em microsserviços, mas parece monólito."

**Resposta:** Correto. Tecnicamente, o backend é um monólito modular — uma única aplicação Spring Boot, bem separada em camadas (`controller` → `service` → `repository` → `entity`), e não um conjunto de microsserviços independentes. A separação "clara entre camadas" existe; o termo "microsserviços" na documentação é impreciso e deve ser ajustado.

Isso não é uma limitação para o estágio atual, e não impede escala horizontal: a API é stateless (autenticação por JWT, sem sessão em memória), então pode rodar em N réplicas atrás de um load balancer. As fronteiras de módulo já existentes facilitam uma eventual extração para microsserviços no futuro, se o volume justificar.

**Ressalva de escala:** dois pontos hoje são "stateful" e precisam de atenção antes de escalar para múltiplas réplicas: (1) o rate limit de login é em memória por instância — para um limite global, migrar para um store distribuído

(ex.: Redis); (2) os anexos são gravados em disco local — ver 4.2.

## 4.2 "Os dados que não vêm do repositório não podem ir para o AWS S3? Isso adiciona muita complexidade de vocês?"

**Resposta:** Sim, podem — e essa é, inclusive, a abordagem recomendada. Hoje os dados relacionais (itens, claims, usuários, auditoria) ficam no MySQL e continuam lá; o que grava em disco local são apenas os binários (fotos de itens e comprovantes de posse), no diretório `app.arquivos.dir`. É exatamente isso que obriga a tratar volume persistente (PVC) e prende as réplicas ao mesmo disco.

Migrar esses binários para AWS S3 (ou compatível, como MinIO) não adiciona complexidade relevante do nosso lado, porque todo o I/O de arquivos já está isolado em um único componente (`ArquivoService`). A mudança se resume a:

- Introduzir uma interface `StorageService` com uma implementação para S3 (AWS SDK v2);
- Trocar a gravação/leitura em disco por `putObject` / `getObject` — o restante do fluxo (autorização, metadados no banco, IDs assinados) permanece idêntico;
- Opcionalmente, gerar URLs pré-assinadas para download, tirando o tráfego de binários da API e mantendo o mesmo modelo de permissão.

**Ganhos:** réplicas 100% stateless (sem PVC), durabilidade e backup gerenciados pelo S3, e simplificação da infraestrutura de contêiner. **Estimativa de esforço:** baixa — é um adaptador localizado, não uma reescrita. **Observação:** o único módulo que realmente precisa de armazenamento externo é o de anexos.

## 4.3 "Ainda não ficou claro como tratam o OWASP Top 10."

**Resposta:** O tratamento está detalhado na Seção 3 deste documento, categoria por categoria (A01 a A10), cada uma com o controle correspondente e o arquivo de evidência no código — não é um selo de marketing, e sim controles verificáveis. Em resumo: acesso e autenticação são os pontos mais fortes (JWT, rate limit, autorização granular, IDs assinados); os pontos com recomendação aberta são hardening de configuração (TLS no banco), scan bloqueante no pipeline e auditoria de acesso a dados sensíveis para LGPD. O cruzamento com a varredura DAST externa (Seção 6) confirma esse quadro do lado da configuração HTTP.

## 4.4 "Preventivamente, com avaliação contínua de risco: há etapa de validação de código no pipeline?"

**Resposta:** O pipeline (`.gitlab-ci.yml`) tem 4 estágios — `build` → `test` → `security` → `deploy` — e o estágio de segurança foi ampliado. Situação atual:

| Verificação                       | Situação             | Observação                                                                                                                                   |
|-----------------------------------|----------------------|----------------------------------------------------------------------------------------------------------------------------------------------|
| Testes automatizados (gate)       | Presente + reforçado | O estágio <code>test</code> sobe um MySQL efêmero no CI, então os testes de integração realmente executam. Falha de teste bloqueia o deploy. |
| SCA — dependências (A06)          | Presente             | Trivy (HIGH/CRITICAL) com <code>--exit-code 1</code> — o job fica visível/vermelho quando há CVE.                                            |
| SAST — análise estática (A05/A08) | Adicionado           | Semgrep com regras públicas de Java, segredos e OWASP Top 10.                                                                                |
| Secret scanning                   | Adicionado           | gitleaks — detecção de chaves/tokens/senhas commitados.                                                                                      |

| Verificação | Situação             | Observação                                                                                                                                                         |
|-------------|----------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| DAST        | Parcial<br>(externo) | Varredura DAST executada pela XPTO (ZAP/nuclei) em 20/07/2026 — ver Seção 6. Sugerido integrar OWASP ZAP autenticado contra staging no pipeline em fase posterior. |

**Estratégia de rollout:** os três jobs de segurança (SCA, SAST, secret scanning) entram como `allow_failure: true` — rodam e ficam visíveis a cada pipeline, mas não bloqueiam a entrega enquanto a equipe faz a primeira triagem. Depois, cada um vira gate bloqueante apenas removendo o `allow_failure`.

**Validação em execução real & ajustes:** (a) o SCA escaneia o artefato empacotado (fat-jar), de forma offline — evita rate-limit ao resolver o repositório Maven; (b) o secret scanning recebeu allowlist para arquivos de exemplo e placeholders; (c) o SAST apontou dois itens de hardening — um corrigido de imediato (host-header fixo no proxy) e outro registrado como melhoria planejada (contêiner não-root).

## 5. Riscos Remanescentes & Roadmap de Hardening

| Item                                         | Prioridade      | Ação recomendada                                                                                                                                                                                                                                                                        |
|----------------------------------------------|-----------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Teste de autorização autenticado (BOLA/BFLA) | Alta            | <b>Novo (XPTO Seção 6).</b> A varredura externa não exercitou os endpoints reais da API (recebeu o fallback da SPA). Executar DAST autenticado com sessão por perfil + teste manual de acesso horizontal e vertical sobre claims, itens, devoluções, transferências, usuários e perfis. |
| Cabeçalhos de segurança HTTP                 | Concluído       | HSTS, <b>Content-Security-Policy</b> , nosniff, frame-options DENY + frame-ancestors 'none' e Referrer-Policy no SecurityConfig (XPTO M-01, M-02, M-05).                                                                                                                                |
| Verbosidade do handler de erro               | Concluído       | <code>server.error.include-*=never</code> (XPTO M-04). Sem stacktrace/mensagem de exceção nas respostas.                                                                                                                                                                                |
| Exposição do Swagger em produção             | Concluído       | <code>SPRINGDOC_ENABLED=false</code> no ambiente de produção (XPTO M-04). Documentação disponível só em dev/homologação.                                                                                                                                                                |
| Política CORS do backend                     | Concluído       | Origens explícitas e configuráveis por ambiente, sem curinga com credenciais e sem <code>@CrossOrigin</code> local que sobreponha a global (XPTO M-03). Em produção, definir <code>CORS_ALLOWED_ORIGINS</code> com os domínios reais e esvaziar os patterns de localhost.               |
| Rate limit distribuído                       | Alta ao escalar | Migrar Bucket4j para Redis quando houver múltiplas réplicas (limite global).                                                                                                                                                                                                            |
| Armazenamento de anexos em S3                | Média           | Ver 4.2 — habilita réplicas stateless e remove dependência de PVC.                                                                                                                                                                                                                      |
| TLS na conexão com o MySQL                   | Média           | Trocar <code>useSSL=false</code> por conexão cifrada em produção.                                                                                                                                                                                                                       |

| Item                                      | Prioridade | Ação recomendada                                                                                                                                                                                                                                     |
|-------------------------------------------|------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Governança do ativo de terceiro           | Média      | <b>Novo (XPTO Seção 2).</b> A API de apoio está hospedada em domínio de fornecedor externo (terceiro). Formalizar avaliação de risco: cláusulas de segurança, notificação de incidentes, direito de auditoria e tratamento de dados pessoais (LGPD). |
| Promover scans de segurança a bloqueantes | Baixa      | Após triagem inicial, remover <code>allow_failure</code> de SCA/SAST/secret. DAST autenticado opcional.                                                                                                                                              |
| LGPD — retenção & dados sensíveis         | Média      | Confirmar/implementar rotina de retenção/anonimização, criptografia em repouso de campos sensíveis e auditoria de acesso a esses dados.                                                                                                              |

## 6. Referência Cruzada — Relatório DAST Externo (XPTO)

Esta seção mapeia cada achado do *Relatório Técnico de Avaliação de Segurança* da XPTO (varredura de 20/07/2026, OWASP ZAP 2.17.0 + nuclei) à situação no backend desta API. O relatório listou 1 achado Alto (reclassificado como falso positivo) e 5 Médios confirmados. Os ativos `mvp` e `painel` (frontends Angular/nginx) são tratados fora deste documento; aqui detalha-se apenas o que recai sobre a API.

| ID   | Achado (XPTO)                                  | Toca a API? | Situação no backend                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|------|------------------------------------------------|-------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| A-01 | PII Disclosure (nº de cartão em resposta HTTP) | Não         | <b>Falso positivo</b> — instâncias exclusivamente em domínios da Mozilla (telemetria do navegador). Nenhuma sobre a API. Sem ação.                                                                                                                                                                                                                                                                                                                   |
| M-01 | Ausência de Content Security Policy            | Sim         | <b>Corrigido (rev. 1.1)</b> — CSP adicionada em <code>SecurityConfig (default-src 'self', frame-ancestors 'none', object-src 'none')</code> . Ver 2.2.                                                                                                                                                                                                                                                                                               |
| M-02 | Ausência de proteção contra clickjacking       | Sim         | <b>Já tratado (rev. 1.0)</b> — <code>frameOptions().deny()</code> (X-Frame-Options: DENY) + <code>frame-ancestors 'none'</code> no CSP. Aplicado a todas as respostas.                                                                                                                                                                                                                                                                               |
| M-03 | Política CORS permissiva (Allow-Origin: *)     | Sim         | <b>Já tratado</b> — as instâncias detectadas eram de recursos do Cloudflare ( <code>/cdn-cgi/</code> ), não da API. Config efetiva: origens explícitas via <code>AppCorsProperties</code> , sem curinga com credenciais e sem <code>@CrossOrigin</code> sobrepondo a global. Em produção, definir os domínios reais.                                                                                                                                 |
| M-04 | Swagger e endpoint de erro expostos            | Sim         | <b>Já tratado</b> + <b>reforçado (rev. 1.1)</b> — Swagger desligável em produção ( <code>SPRINGDOC_ENABLED=false</code> ); <code>/error</code> agora sem verbosidade ( <code>server.error.include-*=never</code> ). Spring Actuator está presente apenas para o health check do container, com exposição restrita a <code>/actuator/health</code> e <code>show-details=never</code> — exatamente a opção aceitável indicada pelo relatório. Ver 2.2. |

| ID   | Achado (XPTO)                        | Toca a API? | Situação no backend                                                                                                                                                                                                                                   |
|------|--------------------------------------|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| M-05 | Ausência de HSTS / conteúdo via HTTP | Sim         | <b>Já tratado (rev. 1.0)</b> — HSTS 1 ano com <code>includeSubDomains</code> no <code>SecurityConfig</code> . Redirecionamento HTTP→HTTPS e "Always Use HTTPS" ficam na borda (Cloudflare/nginx). API é stateless por Bearer (sem cookies de sessão). |

**Limitação relevante do relatório externo.** A XPTO registrou que 87% das respostas do painel retornaram HTML e que os alertas de "XSS potencial" apontavam para a meta tag `viewport` — sinal de que as requisições aos endpoints `/api/v1/*` foram atendidas pelo *fallback* da SPA, não pela API. Portanto, a ausência de achados na camada de API **não** é evidência de segurança dessa camada. As classes não avaliadas (autorização em nível de objeto/função, gestão de sessão, lógica de negócio de claims) estão no roadmap da Seção 5 e devem ser cobertas por DAST autenticado + teste manual de autorização.

## 7. Conclusão

O backend entrega uma fundação de segurança sólida e coerente com boa parte do que a documentação promete: os controles centrais de autenticação, autorização e integridade estão implementados e são verificáveis no código. A vulnerabilidade mais séria encontrada (leitura arbitrária de arquivo) foi corrigida na revisão 1.0. O cruzamento com a varredura DAST externa da XPTO (Seção 6) não trouxe nenhum achado explorável na API: dos cinco Médios confirmados, os que tocam o backend já estavam tratados ou foram fechados nesta revisão 1.1 (CSP e verbosidade do handler de erro).

Os itens remanescentes são melhorias de hardening e de maturidade operacional — principalmente o **teste de autorização autenticado** (a lacuna real apontada pela limitação da varredura), armazenamento externo (S3) para escalar sem PVC, rate limit distribuído, TLS no MySQL, a governança do ativo de terceiro e as pendências de LGPD — todos de esforço controlado e sem reescrita de arquitetura. Recomenda-se, ainda, ajustar a documentação funcional para refletir que a solução é um monólito modular stateless, e não microsserviços.